DEV-08 · Mobile Device Access to Organization Data

Your phone became part of the organization's security perimeter the day you set up Authenticator. What that means, what we can and cannot see, and what to do when you change phones.

Field	Value
Document ID	DEV-08
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	C. Device Usage
Operating tier	Tier 1 — the front door handles almost everything in this document: setting up mail on a phone, the phone-change case in §9, and answering "what can you see?". Tier 3 owns the app protection and Conditional Access configuration; Tier 4 approves full enrollment and the §10 cutover.
Review cycle	Annually, and on any change to the MFA method position in ACC-03.
Relationship to DEV-07	DEV-07 sets the bargain for any personally-owned device and is written to be read by the device's owner. This document is the mobile-specific standard underneath it: the three postures, the settings, wipe scope, and the phone-change procedure. Where they overlap, DEV-07 §5 is the organization's privacy statement and §3 here must match it exactly. If they ever diverge, that is a defect (GOV-01).

1. Purpose — the day your phone joined the perimeter

Almost everybody thinks of their phone as outside the organization's world. It is their own property, bought with their own money, full of their own life. That instinct is correct about the phone and wrong about one app on it.

> **The moment you registered Microsoft Authenticator, your phone became the thing that proves you are you.**
>
> It is no longer only a device that reads organization mail. It is the second factor on your organization identity — the object that approves a sign-in to your mailbox, your files, your business systems and everything the organization has connected to that identity.
>
> That is true whether or not you read email on it. A phone with Authenticator and nothing else on it is more security-relevant than a phone with the whole Microsoft 365 suite and no MFA method.
>
> Which means two things. The organization has a legitimate interest in a small, specific part of your phone — and a corresponding obligation to be precise about how small that part is (§3).

The second reason this document exists is a specific, common failure: a service desk receives a request to fix an Authenticator sign-in problem. It arrives from a personal Gmail address, on behalf of a person with a different name, and nobody records any verification of who was asking before acting.

That is the exact shape of a help desk social-engineering attack: the request is plausible, the sympathy is genuine, the pressure is real, and the account being changed is the one thing protecting everything else. Section 9 is the procedure whose absence makes it possible, and it is written as a step sequence for that reason.

2. The three postures, and which one the organization should adopt

Posture	What the organization applies	Who it is for	Assessment
Unmanaged device, protected apps (app protection / MAM-WE)	Protection applied to organization data inside organization apps: a PIN or biometric to open them, encryption of organization data at rest, no copying organization data into personal apps, and the ability to remove organization data and nothing else. The device itself is not enrolled and not managed.	Every personally-owned phone and tablet. This is the default and it should cover the great majority of devices.	RECOMMENDED. It achieves the actual objective — protecting organization data — without the organization acquiring any control over somebody's personal property. It is also the posture people will accept, which matters, because a posture nobody accepts does not get adopted.
Fully enrolled (MDM)	The device is enrolled and managed: configuration profiles, compliance policy, app deployment, restrictions, and — where the platform allows — a full device wipe.	Organization-owned mobile devices only: a small number of shared or role phones and tablets, department iPads, kiosk and check-in tablets.	Correct for organization property, wrong for personal property. Full enrollment of a personal phone should be rare and by explicit agreement (DEV-07 §3), and the better answer is almost always to issue an organization device instead.
Unmanaged, no controls	Nothing. Organization mail and files reach the device through whatever client the person chose, with no PIN requirement, no encryption requirement, no restriction on where the data goes, and no way to remove it.	Nobody, by design. In many organizations it is the status quo.	Where this is where you are today, the honest assessment is: organization data — including client records read in Outlook — is on an unknown number of phones. The organization cannot say how many, cannot require a passcode on any of them, and cannot remove its data from a single one. When somebody leaves, the mail app on their phone keeps working until the account is disabled, and nothing after that is verifiable.

The recommendation is therefore: app protection required for personally-owned devices, full enrollment for organization-owned devices only, and the third posture closed — in that order, on the sequence in §10.

3. What the organization can and cannot see on a personal phone

This is the single biggest obstacle to adoption, and honesty is the only thing that removes it. People decline app protection because they assume it means the organization can read their messages and see their photos. It does not, and the fix for that assumption is not reassurance in general terms — it is a table.

Under app protection, on a device that is not enrolled:

The organization can see	The organization cannot see
That a device is being used with your organization account, and its make, model and operating system version.	Your photos, videos or personal files.
Whether organization apps on it meet the protection requirements (§4).	Your personal messages, iMessage, WhatsApp, or your calls and call history.
Which organization apps you use, and when organization data was last synchronised to them.	Your other apps, or which apps you have installed at all.
Sign-in activity for your organization account — as for any device, including an organization laptop.	Your browsing history, other than organization sites opened in a managed organization browser profile.
That the device reports itself as jailbroken or rooted, if it does.	Your location. There is no location capability under app protection, and the organization does not want one.
That organization data was removed, when the organization removes it.	Your personal email accounts — including a personal account added to the same Outlook app, which is separate and unmanaged.
Your mobile number, but only if you registered it yourself as an MFA or password-reset method.	Your contacts, calendar or notes, other than the organization ones inside organization apps.

- There is no mechanism under app protection for the organization to read personal content on a personal device. It is not that the organization chooses not to; the capability does not exist in this posture.
- The organization cannot wipe your phone under app protection. It can remove organization data from organization apps, which is a different action with a different scope (§6).
- Access to sign-in or mailbox logs for a security investigation is a Tier 4 decision with a recorded reason, and where it concerns an employee, HR is involved from the start (ACC-15 §6).
- Under full enrollment the organization can see and do considerably more — installed application inventory, configuration state, and on organization-owned hardware a full wipe. That is exactly why §2 restricts full enrollment to organization-owned devices.
- This table must stay identical in substance to DEV-07 §5. Two documents giving different answers to “what can you see?” is worse than neither document existing.

4. The app protection baseline

Recommended settings for personally-owned devices. Each is chosen because it protects organization data rather than because the platform offers it — and two of them are deliberately not set, which is stated here so the omissions are decisions rather than oversights.

Setting	Requirement	What the person experiences
PIN or biometric on organization apps	Required. Six digits minimum, or the device biometric. Re-prompt after 30 minutes of inactivity.	Face or fingerprint when opening Outlook or Teams after a break. On most phones this is unnoticeable.
Encryption of organization data at rest	Required within organization apps.	Nothing visible.
Minimum operating system	Recommended: the current major version and the one before it for iOS and iPadOS; Android 13 and above. Reviewed every six months with a published floor.	A device below the floor cannot use organization apps. This falls hardest on people with older phones, which is a real cost — the mitigations are Outlook on the web, or an organization device.
Jailbreak / root detection	Blocked. Organization data is removed from organization apps on a device reporting as jailbroken or rooted.	Affects a very small number of people, who will know why.
Copy and paste out of organization apps	Blocked into unmanaged apps. Paste into organization apps is allowed, and copying within organization apps is allowed.	The most-noticed restriction. Pasting a paragraph from organization email into a personal note will not work.
Save As to personal storage	Blocked. Saving to OneDrive for Business and SharePoint is allowed.	An organization attachment cannot be saved to personal iCloud, Google Drive or the phone’s local files.
Backup of organization data to iCloud or Google	Blocked.	Nothing visible.
Offline grace	Organization data removed from apps after 30 days with no check-in; access blocked after 12 hours offline for the most sensitive apps is NOT recommended — it punishes travel.	A phone left in a drawer for a month will ask you to sign in again.
Screen capture (Android)	NOT blocked — recommended. The platform allows it, and blocking it stops people photographing a schedule or a room number while providing very little protection against anybody determined.	Screenshots continue to work.

Setting	Requirement	What the person experiences
Third-party keyboards	NOT blocked — recommended, with a note. Blocking them breaks accessibility and multilingual input for the people who most need them. The risk is real but the control is disproportionate.	Your keyboard keeps working.
Which apps are managed	Outlook, Teams, OneDrive, Word, Excel, PowerPoint, OneNote, SharePoint, and Edge for organization sites. Authenticator is treated separately (§8).	These are the apps to install. The organization publishes the list rather than leaving people to guess.
Unmanaged mail clients	Blocked once app protection is live — the built-in iOS Mail app, the Android mail client, and any third-party client, all of which reach mail without any of the protections above.	This is the change that will affect people. See §10; it needs sequencing and warning, not an announcement.

> **The policy only bites when the unmanaged path is closed**
>
> App protection policies apply to organization apps. They do nothing at all about a phone reading organization mail through the built-in Mail app, because that path never touches a managed app.
>
> So the control that actually delivers this document is a Conditional Access policy requiring an approved client application with an app protection policy applied. Until that is in place, §4 is a recommendation that protects the people who were never the risk.
>
> And that policy will stop some people's mail working on the day it turns on. Everybody currently using the built-in Mail app has to move to Outlook first. That is §10, and the classic MFA setup loop shows what happens when a control is enforced against a population that cannot yet satisfy it (ACC-03 §11).

5. Organization-owned mobile devices

- Organization-owned phones and tablets are fully enrolled, and appear in inventory like any other device (DEV-01). An organization iPad in a department drawer with no enrollment record is an untracked asset holding organization data.
- Apple devices are enrolled through Apple Business Manager and Automated Device Enrollment, which requires them to have been bought through an ABM-linked channel — the same purchasing rule that governs Macs, and the same failure if it is not followed (DEV-09 §3, DEV-04 §3).
- Shared tablets — check-in stations, event devices, meeting room sets — run as shared or single-app devices with no persistent personal state, on the same principle as a lab machine (DEV-06 §2).
- An organization mobile device issued to one named person carries the same rules as an organization laptop: it is organization property, subject to the Acceptable Use Policy, returned at separation, and wiped and recorded through DEV-15 when it is retired.
- Personal use of an organization phone is a reasonable thing to permit and should be stated explicitly one way or the other, because a full wipe of an organization device takes the personal photographs with it and the person deserves to have known that in advance.

6. Selective wipe, full wipe, and the lost phone

	Selective wipe (organization data only)	Full wipe (whole device)
What it removes	Organization mail, files, Teams content and cached organization data from managed apps. Personal content, apps, photos and accounts are untouched.	Everything on the device, returning it to factory state.
Applies to	Any device, personally-owned or organization-owned. The default action in every case.	Organization-owned devices only.
When	Separation (§7), a lost or stolen device, a device reporting jailbroken or rooted, a device that has not checked in for 30 days, or on the owner's request.	A lost or stolen organization device with no prospect of recovery; an organization device being retired or reassigned (DEV-15).
Who authorises	Tier 2, on the leaver record or the lost-device report. It does not need a Tier 4 decision, because its scope is organization data.	Tier 4. A full wipe is irreversible and takes anything of the user's with it.
On a personal device	Yes — this is the mechanism the whole document rests on.	Never. Not on personal property, not as a convenience, not because the platform offers the button. Only with the owner's explicit, contemporaneous agreement, recorded (DEV-07 §6).

6.1 The lost or stolen phone

A lost phone is two incidents at once, and the second one is the one people forget: it is a data event and an identity event. DEV-16 is the full procedure; what is specific to a phone is the identity half.

1. The person reports it — one number, immediately, without waiting to be sure it is not just in the car (DEV-16 §2). Nobody is ever criticised for reporting a phone that turns up.
2. Selective wipe queued for organization data. It executes when the device next has a network connection, which may be never — so this is a mitigation, not a guarantee, and it should be described that way.
3. Sign-in sessions revoked, so a signed-in app on that phone stops working rather than continuing until its token expires.
4. If that phone carried an MFA method — which it almost certainly did — that method is removed, and the person needs another way to sign in. This is the step that makes a lost phone urgent rather than merely annoying.
5. The person is verified in person or by the ACC-06 standard before any method is re-registered. A lost phone is the ideal pretext for an attacker, and the request will arrive by exactly the route real impersonation attempts arrive by.
6. Where the phone held CONFIDENTIAL or RESTRICTED material beyond what a mailbox ordinarily holds, GOV-03 is engaged. Where it is a theft, DEV-16 §7.

7. When you leave

- Organization data is removed from organization apps on your device. Your phone, your photos, your personal accounts and your apps are untouched (§6).
- This happens as part of the leaver procedure (ACC-01 §7.2) and is not discretionary or personal.
- Your MFA methods are removed with the account, which is why the Authenticator entry for the organization disappears. Delete it from the app at your leisure; it no longer does anything.
- If your mobile number was registered for SMS or self-service password reset, it goes with the account. The organization does not retain a personal number after separation for any other purpose.
- Retiree and affiliate accounts continue to exist under ACC-12, and so does the app protection requirement on them. A retained account with a phone reading its mail is still an account inside the perimeter.
- If anything of yours is genuinely mixed into organization storage, say so before your last day. It is far easier to separate then than afterwards, and afterwards it may not be possible at all (M365-16).

8. The identity dimension — Authenticator, passkeys and SMS

This section is the reason a mobile standard belongs to Tier 1 rather than to a device team. ACC-03 is the governing document for methods; what follows is the phone-shaped view of it.

Method	Position	Why
Microsoft Authenticator push with number matching	The current standard method for most people.	Resistant to blind approval fatigue, because the number must be read from the sign-in screen. Still phishable in principle by a determined real-time attacker, which is why it is not the destination.
Passkey in Authenticator, or a platform passkey (Face ID / fingerprint on the device)	The direction of travel, and the recommended method for anybody willing to set it up now.	Phishing-resistant: the credential is bound to the site and cannot be replayed by an attacker who has intercepted it. This is what vendor phishing-resistant MFA requirements are actually asking for.
FIDO2 security key	Recommended for privileged and administrative accounts (ACC-07), and as the second method for anybody whose phone is their only factor.	Phishing-resistant and independent of the phone entirely — which is precisely its value in the phone-change and lost-phone cases.
SMS and voice call	Enabled today as fallback. A weak factor, and the direction is to disable it.	Interceptable, and vulnerable to SIM-swap — an attacker who persuades a mobile carrier to move a number receives the codes. It is also the method people fall back to on a new phone, which is exactly the moment verification matters most (§9).
A single method, whatever it is	Not acceptable, and the commonest real problem.	One method on one phone means one lost, stolen, broken, wet or traded-in phone is a verified in-person recovery. Two methods, on two different things, is ninety seconds of setup that saves a bad afternoon.

On the direction of travel: SaaS vendors are increasingly enforcing phishing-resistant MFA by fixed dates. That is a hard external date against a control with a classic failure mode — a rushed rollout that leaves people stuck in an MFA setup loop. The lesson recorded in ACC-03 §11 applies here without modification: register the method across the population first, verify from the authentication-methods report that they hold it, run report-only, and only then enforce. SMS is disabled after that, not before, because disabling the fallback while people still depend on it is how the setup loop happens.

---

9. Changing your phone

This is one of the most common calls Tier 1 takes and one of the most painful when it goes wrong, because the person is locked out of everything at once and their proof of identity was on the phone they no longer have. It deserves a written procedure on both sides.

9.1 The good path — you still have the old phone

1. Before you do anything else with the new phone, install Microsoft Authenticator on it.
2. Add your organization account as a new method from the new phone. Sign in and approve the prompt on the OLD phone — this is why doing it before the trade-in matters, and it is the whole trick.
3. Confirm both methods now appear on your account, then remove the old phone's method yourself.
4. Install the organization apps on the new phone: Outlook, Teams, OneDrive. Sign in. Set the PIN or biometric when prompted (§4).
5. Only now factory-reset, sell or trade in the old phone. Signing out of the organization account is not the same as removing the device; do the reset.
6. Total elapsed time: about five minutes, no ticket, no verification appointment.

9.2 The recovery path — the old phone is gone, broken or wiped

1. If you have a second registered method — a security key, a passkey on a laptop, or Authenticator on a tablet — use it. This is the entire reason for having one, and no further procedure is required.
2. If you have no other method: contact the service desk. This is a verified recovery, not a reset, and it will take longer than you want it to.
3. IT verifies your identity to the ACC-06 standard for a method change — which is the highest verification tier the organization operates, because re-registering an MFA method is functionally the same as handing somebody the account (ACC-06 §4, §5).
4. IT issues a Temporary Access Pass or equivalent, valid briefly and once, forcing re-registration at next sign-in (ACC-03 §5).
5. You register at least two methods this time, and IT should insist on it rather than leaving it as advice.
6. The verification performed, and by whom, is recorded on the ticket. Not "verified"; what was checked (ACC-06 §9).

> **The request IT will not action, however genuine it looks**
>
> A common failure: an Authenticator request arrives at the service desk from a personal email address, on behalf of a person with a different name, and is acted on with no verification recorded.
>
> So, explicitly: IT does not add, remove or reset an MFA method on the strength of an email from an address that is not the account holder's organization address; on the strength of a request made by somebody else on the holder's behalf — including a manager, an assistant, a spouse or a colleague being helpful; or because the request is urgent and the person is travelling and stuck.
>
> Every one of those is a legitimate-sounding request that an attacker would make word for word. The verification in ACC-06 is not an obstacle to the account holder; it is the only thing standing between an attacker and the account. Where a request cannot be verified, it is declined with the script in ACC-06 Appendix B — courteously, and with the route that will work.
>
> This applies with no exception at Tier 1, and no member of staff can waive it by seniority or by pressure (ACC-06 §10).

The practical prevention, which Tier 1 should say out loud in every conversation about phones: register a second method now, on something that is not your phone. It converts §9.2 into §9.1.

10. Cutover — from no controls to app protection

Element	Current state — governs today	Target state
Access from a personal phone	Any client, no controls, no inventory. Unknown population.	Approved organization apps only, with app protection applied, enforced by Conditional Access.
PIN on organization data	Whatever the person has on their phone, if anything.	Required on organization apps (§4).
Built-in Mail app / third-party clients	Working, and used by an unknown number of people.	Blocked. This is the change people will feel.
Removing organization data	Not possible. The organization can disable the account and hope.	Selective wipe, on the leaver record or on report (§6).
organization-owned phones and tablets	Mixed; some enrolled, some not, some not in inventory.	Fully enrolled, in inventory, ABM-linked where Apple (§5).
MFA methods	Typically Authenticator push (and sometimes a legacy provider's app), with SMS and voice as fallback (ACC-03 §3).	Passkeys and phishing-resistant methods as the standard; SMS and voice disabled — after registration, not before (§8).

Cutover trigger, and the order that avoids the setup loop

1. Publish Appendix A first. People need to know what the organization can and cannot see before being asked to accept anything (§3). This step is not optional and it is not marketing.
2. Make the target work before blocking the source. Outlook, Teams and OneDrive available, app protection applied, and a Tier 1 script for setting them up (§11).
3. Measure who is affected. Identify the population still using unmanaged mail clients, from sign-in data, before anything is switched. A cutover against an unmeasured population is the classic mistake.
4. Warn that population by name, twice, with a date and a how-to. Not a broadcast to everybody, which the affected people will not read as being about them.
5. Run the Conditional Access policy in report-only for at least ten business days and read the would-be-blocked report daily.
6. Enforce by wave, smallest and best-understood population first, with Tier 1 briefed and staffed for the day.
7. Only then consider disabling SMS as an MFA method (§8), and only against the evidence that the population holds another one.

Where a hard external date exists — a vendor's phishing-resistant requirement, say — it moves the affected population to the front of the wave order. It does not license skipping steps 3 to 5; that is precisely what produces an MFA setup loop.

11. Service levels

Activity	Commitment (per GOV-06)
Help setting up organization mail on a phone	P3 — Tier 1, usually within the same conversation.
"What can you see on my phone?"	Answered at Tier 1 from §3, immediately. A fair question that deserves a straight answer, not an escalation.
Phone change, old phone available (§9.1)	Self-service. Tier 1 talks it through in about five minutes if asked.
Phone change, no other method (§9.2)	P2 — verified recovery within one coverage day. Not faster, because the verification is the control.
Lost or stolen phone holding organization data	P1 — selective wipe queued and sessions revoked within 1 coverage hour of report (DEV-16).
MFA method removed after a lost phone, person unable to work	P1 — but only after ACC-06 verification. The clock does not license skipping it.
Device below the minimum OS floor	P3 — Tier 1 explains, offers web access or an organization device. Not treated as a fault.
Full enrollment request for a personally-owned device	P3 to Tier 4 — expect to be offered an organization device instead (DEV-07 §3).
Organization data removal at separation	With the ACC-01 leaver procedure, same day as the account action.

12. Records

Record	Held in	Retention
Devices with app protection applied — model, OS, last check-in	Management platform	While in use
Organization-owned mobile devices, assignee and enrollment state	Inventory	Life of the device + 3 years
Selective wipes: device, reason, who authorised, outcome	Ticket	3 years
Full wipes of organization devices, with Tier 4 approval	Ticket + Tier 4 record	7 years
Full enrollment agreements for personally-owned devices, with recorded consent	Ticket + Tier 4 record	Life of the arrangement + 3 years
MFA method changes, with the verification performed and by whom	Ticket	3 years — the field is mandatory (ACC-06 §9)
Declined or unverifiable method requests, including who asked	Security record	3 years — the pattern matters more than the case
Cutover evidence: report-only findings, waves, affected population	Tier 4 record	7 years

13. Related documents

ID	Title	Relationship
AUP	Your organization's acceptable use policy	Applies to a personal phone used for organization work exactly as to an organization device.
DEV-07	Personally-Owned Device Access Standard	The bargain, and the privacy statement §3 must match. Read first by anybody whose device it is.
DEV-16	Lost, Stolen or Compromised Device Response	§6.1 is the phone-shaped view of it.
DEV-01	Device Enrollment & Lifecycle	Organization-owned mobile devices are enrolled and inventoried there.
DEV-09	macOS Device Management Standard	§3 — the ABM purchasing rule, which applies to iPhones and iPads too.
DEV-15	Device Reassignment, Wipe, Retirement & Disposal	Retirement of an organization phone or tablet.
ACC-03	MFA & Account Recovery	The governing document for methods, the Temporary Access Pass path, and the §11 rollout lesson.
ACC-06	Identity Verification	The verification standard §9.2 depends on. The §1 request is a failure of this control, not of a mobile setting.

ID	Title	Relationship
ACC-01	Account Lifecycle	§7 — removal at separation.
ACC-12	Separation, Retiree & Former-Member Disposition	Retained accounts stay inside the perimeter, and so do their phones.
ACC-07	Privileged Account Standard	Privileged accounts use phishing-resistant methods and are not administered from a phone.
ACC-15	Acceptable Use & Credential-Sharing Standard	Never approve a prompt you did not trigger; the monitoring position in §6.
M365-15	Data Classification & Handling	What may be opened on a phone.
M365-22	Phishing Reporting & Email Threat Response	Where a suspicious prompt or message goes.
GOV-03	Security Incident Response	A lost phone that is more than a lost phone.
GOV-06	Service Commitments, Priority & Escalation	Supplies §11.

Appendix A — Getting your work email on your phone, and what we can and cannot see

Source text for the knowledge base, publishable as written. Format per GOV-05. This is the article that has to exist before anything in §10 is switched on.

Yes, put your organization email on your phone	Most people do, and it is genuinely useful. Install Outlook, Teams and OneDrive from your app store, sign in with your work address, and that is it. If you get stuck, the service desk will do it with you in about five minutes.
Use Outlook, not the mail app that came with your phone	We know that is a small annoyance if you have used the built-in Mail app for years. The reason is simple: we can protect organization email inside Outlook, and we cannot protect anything inside the built-in app. Everything else on your phone stays exactly as it is either way.
What we can see	That your phone exists, its make, model and operating system version, that organization apps on it are protected, and when organization data last synced. Plus the sign-in activity on your organization account, which we can see for any device including an organization laptop.
What we cannot see	Your photos. Your personal messages. Your calls. Your other apps, or which apps you have. Your browsing. Your location. Your personal email — even if it is in the same Outlook app, it is separate and we cannot touch it. We have no way to look at any of that, and we do not want one.
What we can remove, and what we cannot	We can remove organization email and organization files from organization apps — if your phone is lost, or when you leave. We cannot wipe your phone. Your photos and everything else of yours are not ours to touch and we could not do it if we tried.

What you will notice day to day	Face ID or a PIN when you open Outlook after a while. You will not be able to copy text out of organization email into a personal note, or save an organization attachment into your personal cloud storage. That is the whole of it.
What not to put on your phone	Do not download client records, job applicant files or personnel records onto a phone. Read them in the app instead. Never anything with social security numbers, card details or health information — those do not belong on a personal device at all.
Your Authenticator app is the important one	That is the app that proves you are you. Keep a passcode or Face ID on your phone — that is the real protection — and please register a second way of signing in, on something that is not your phone. A security key, or Authenticator on a tablet. It takes ninety seconds and it is the difference between a five-minute fix and an appointment with photo ID.
Getting a new phone? Do this first	Before you trade in or reset the old one: install Authenticator on the NEW phone, add your organization account to it, and approve the prompt on the OLD phone. Then check both are listed, then wipe the old phone. Five minutes, no ticket. If the old phone has already gone and you have no other sign-in method, we can still get you back in — but we will have to verify who you are properly first, and that takes longer.
If your phone is lost or stolen	Tell us straight away, even if you think it might turn up in the car. We will remove organization data from it and stop it approving sign-ins. Nobody has ever been told off for reporting a phone that then turned up.
Why we will not just take your word for it	If somebody rings us claiming to be you and asks us to move your sign-in method to a new phone, and we do it, they now have your account — your mail, your files, and everything the organization connects to it. It is a common attack. So we will always check who you are before changing anything, including when you are in a hurry, and including when it is obviously really you. It is not about you; it is the only thing protecting you.
If you would rather not have organization email on your phone	Then do not. There is no expectation and no consequence. Outlook on the web works fine from any browser, and plenty of people prefer to leave work at work.

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.